

RiskTwin

AI-Powered Cyber Risk Simulation & Compliance Intelligence

Project Report

Fictional case study: AtlasPay — Moroccan fintech

By Chakir Chaimaa & Haytham Elgana

github.com/chaimaachk/RiskTwin-AI-Cyber-Risk-Digital-Twin

GOMYCODE®



Built at a GoMyCode hackathon, powered by NVIDIA AI models

Contents

1. Executive Summary
2. Problem & Positioning
3. Technical Architecture
4. Data Model — AtlasPay
5. Risk Engine (Deterministic Scoring)
6. Risk Visualization — Heatmap & Distribution
7. What-If Simulation Engine
8. NVIDIA Infrastructure (Brev & NIM Integration)
9. ISO 27001 / NIST CSF Mapping
10. Document Intelligence — Evidence Analysis
11. Application Screens
12. Tech Stack
13. Project Status
14. Demo Script
15. Appendix — Full Data Reference
16. Credits

1 Executive Summary

RiskTwin is an AI-powered cyber risk digital twin. It lets an organization's security posture be represented as structured data, scored through a transparent deterministic engine, stress-tested through what-if scenarios, explained in business language by an AI model, mapped to ISO 27001 and NIST CSF controls, and checked against uploaded evidence documents for compliance gaps.

The project separates **calculation** from **explanation**: all risk scores and scenario impacts are computed by fixed, auditable formulas, never by the AI. The AI model (hosted on NVIDIA NIM) is only used to interpret and narrate that structured data into an executive-readable analysis — never to invent scores, assets, or controls.

The full technical core defined in the project plan — Risk Engine, What-If Simulator, AI Analysis, and ISO/NIST Mapping — is built and verified working end-to-end, plus the optional Document Intelligence (Evidence) module.

Metric	Value
Total assets modeled	15
Seeded risks	13
Control topics mapped (ISO/NIST)	15
Predefined what-if scenarios	4
Application screens	5
Overall AtlasPay exposure (baseline)	Critical

2 Problem & Positioning

Most organizations can list their security controls but struggle to answer a simple question: *"What actually happens to our business if this one thing fails?"* RiskTwin answers that question on demand, using a live simulation rather than a static spreadsheet audit.

Positioning: **RiskTwin — AI-Powered Cyber Risk Simulation & Compliance Intelligence**, deliberately distinct from a generic "AI cybersecurity platform." It targets the GRC (Governance, Risk & Compliance) and audit use case rather than SOC/detection tooling.

3 Technical Architecture

The system is a single Streamlit application backed by four independent layers, each with a single responsibility:

- **Data layer** — JSON files describing the organization (assets, risks, controls, scenarios).
- **Risk Engine** — pure Python, deterministic Likelihood x Impact scoring, no AI involved.
- **Scenario Engine** — propagates a chosen what-if scenario across target assets and computes before/after scores using fixed deltas.

- **AI Layer** — sends the structured engine output to an NVIDIA-hosted LLM with a strict instruction not to invent data, and parses a structured JSON response back.
- **Document Parser** — extracts text from an uploaded PDF for evidence-gap analysis.

Repository structure

```
risktwin/  
  data/      assets.json, risks.json, controls.json, scenarios.json  
  engine/    risk_engine.py, scenario_engine.py, doc_parser.py  
  ai/        nvidia_client.py  
  app.py     Streamlit UI (5 screens)  
  requirements.txt
```

Data flow

User selects scenario → Scenario Engine reads assets.json / risks.json / scenarios.json → computes before/after scores → structured payload sent to NVIDIA NIM → AI returns JSON analysis → rendered in Streamlit.

4 Data Model — AtlasPay

AtlasPay is a fictional Moroccan fintech used as the demo organization, with 15 assets spanning identity, applications, infrastructure, and a third-party payment vendor. Each asset record carries an id, name, type, business criticality (1-5), owner, data classification, and internet exposure flag.

Asset	Type	Criticality	Internet-exposed
Active Directory	Identity	5	No
Customer Database	Data Store	5	No
Payment API	Application	5	Yes
Web Application	Application	4	Yes
Employee Laptops	Endpoint	3	Yes
Email Server	Communication	3	Yes
Cloud Storage	Data Store	4	Yes
ERP	Application	4	No
Backup Server	Infrastructure	5	No
VPN	Network	4	Yes
Firewall	Network	4	Yes
Third-Party Payment Provider	Vendor	5	Yes

(Full 15-asset list in Appendix, Section 15.)

Sample asset record

```
{
  "asset_id": "AST-03",
  "name": "Payment API",
  "type": "Application",
  "business_criticality": 5,
  "owner": "Product Engineering",
  "data_type": "Financial",
  "internet_exposed": true
}
```

5 Risk Engine (Deterministic Scoring)

Every risk score is computed the same way, with no AI involvement, so the baseline is fully transparent and auditable:

Risk Score = Likelihood x Impact (both rated 1-5)

Score range	Level	Meaning
1 - 4	Low	Acceptable; monitor only

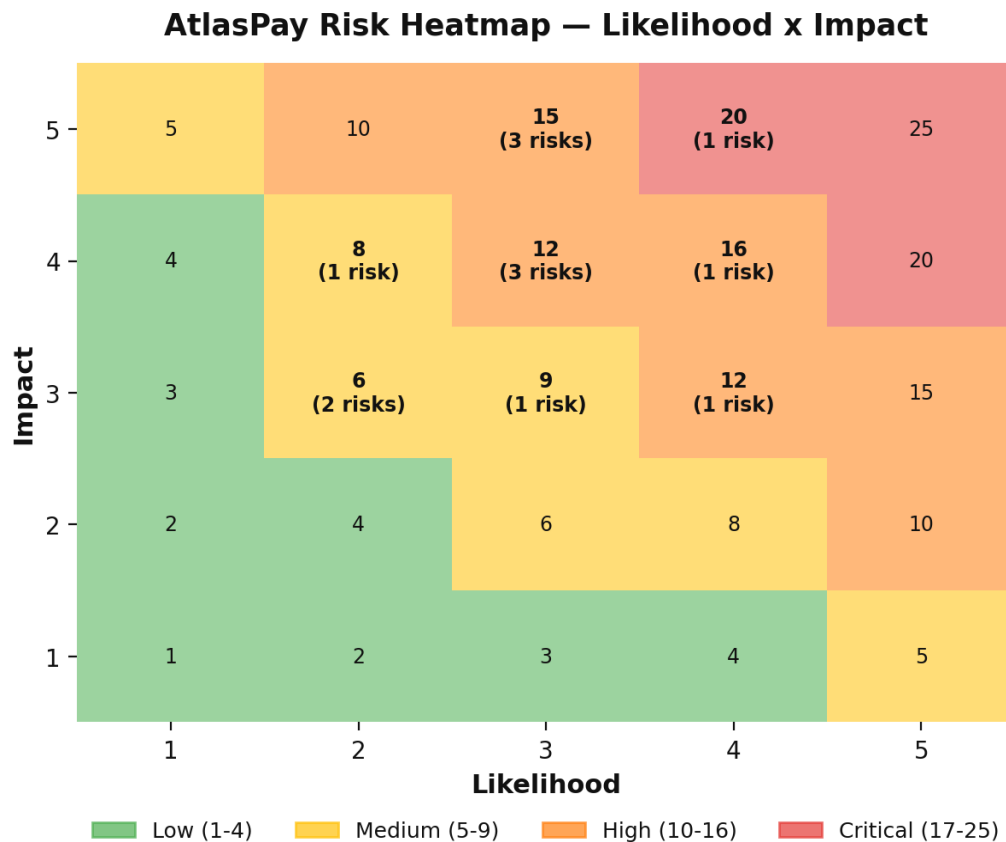
Score range	Level	Meaning
5 - 9	Medium	Track; remediate on normal cycle
10 - 16	High	Prioritize remediation this quarter
17 - 25	Critical	Immediate action required

Worked example — **Credential compromise** on Active Directory: Likelihood 4 ("likely") x Impact 5 ("severe") = 20 → **Critical**. This single formula drives every score in the Risk Register, the Dashboard KPIs, and every what-if comparison.

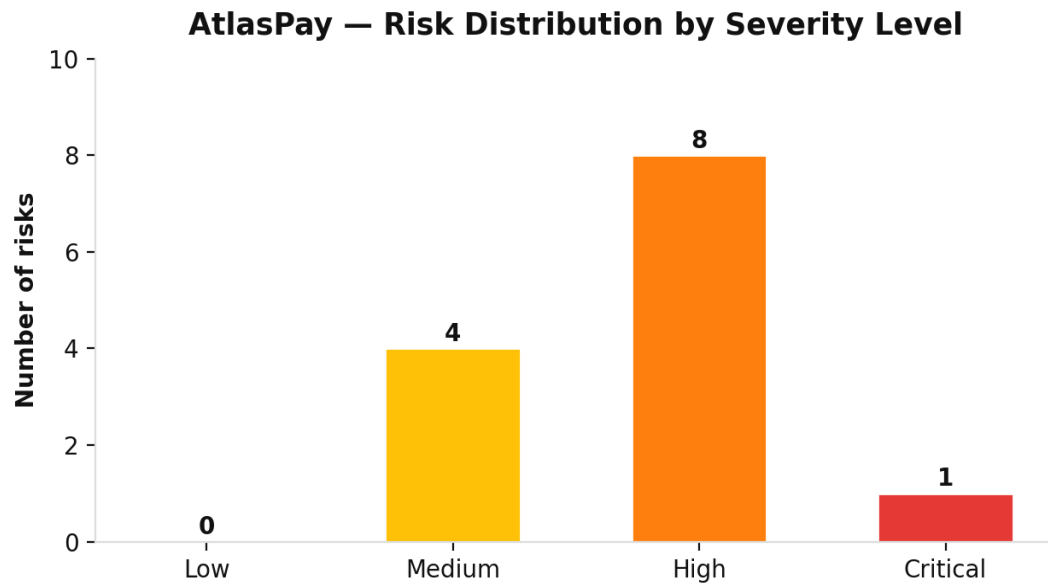
The engine also computes organization-level KPIs shown on the Dashboard: total assets, critical assets, open risks, high-risk count, a control coverage percentage, and an overall exposure rating (Low/Medium/High/Critical) driven by the worst risk level present. Control coverage is computed as $100 - (\text{high_risk_count} / \text{open_risk_count}) \times 100$, giving a simple, reproducible proxy rather than an AI-estimated figure.

6 Risk Visualization

The 13 seeded AtlasPay risks plotted on a standard 5x5 Likelihood x Impact matrix. Cell color follows the same Low/Medium/High/Critical bands as the scoring table; each occupied cell is annotated with how many current risks fall there.



Severity distribution across the current risk register: no Low risks, 4 Medium, 8 High, and 1 Critical — which is why AtlasPay's baseline overall exposure reads as Critical on the Dashboard.



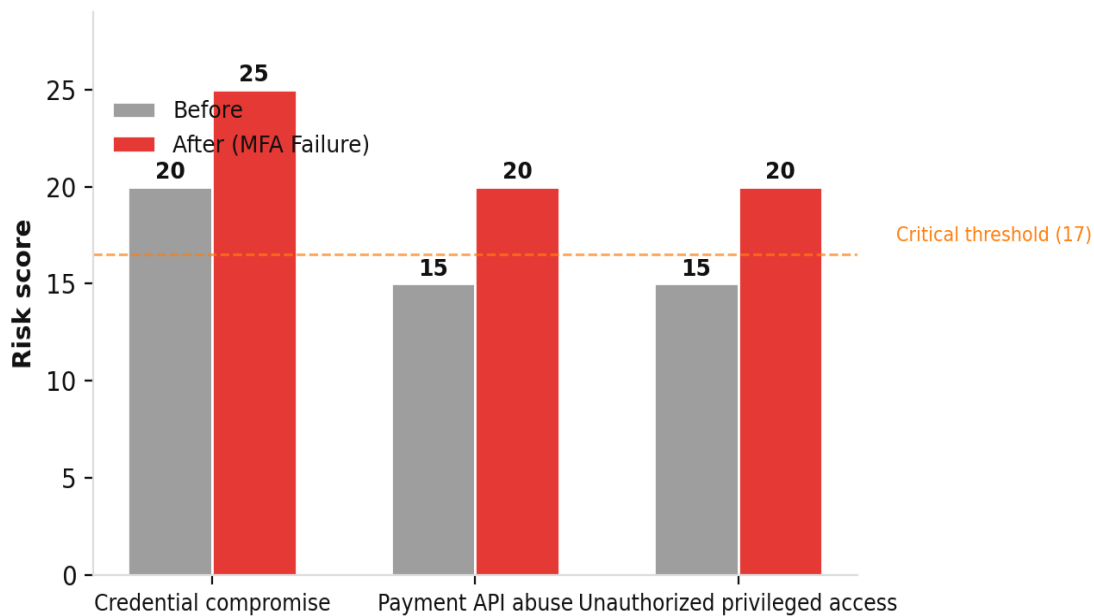
7 What-If Simulation Engine

Four predefined scenarios model realistic incident chains. Each scenario defines which assets it touches and a fixed likelihood/impact delta, so the before/after comparison is reproducible every time it is run — the AI never decides how much a scenario raises risk.

Scenario	Propagation chain	Delta
MFA Failure	Identity -> Privileged Accounts -> Critical Apps -> Customer Data	L +1
Unpatched Critical Vulnerability	Internet-facing App -> Exploit Exposure -> Customer Platform -> Business Service	L +1 / I +1
Third-Party Vendor Breach	Vendor -> API Integration -> Customer Data -> Compliance Exposure	L +1
Backup System Unavailable	Backup -> Recovery Capability -> Business Continuity -> Ransomware Resilience	I +1

Verified run — MFA Failure scenario. This scenario targets Active Directory, the Payment API, and the ERP system, applying a +1 likelihood delta to every risk attached to those assets. The engine correctly escalates all three affected risks, pushing two of them past the Critical threshold:

Scenario Impact — MFA Failure (Before vs After)



8 NVIDIA Infrastructure (Brev & NIM Integration)

NVIDIA Infrastructure & AI Integration Statement

1. Cloud Infrastructure (NVIDIA Brev): To ensure a scalable, secure, and high-performance execution environment, the entire RiskTwin application stack (Streamlit UI, deterministic Python risk engines, and document parsing modules) is deployed and hosted on an NVIDIA Brev cloud instance. This fulfills the hackathon's infrastructure requirement and guarantees low-latency connectivity to NVIDIA's AI endpoints during live simulations.

2. AI Model Integration (NVIDIA NIM): The application integrates the meta/llama-3.1-8b-instruct model hosted on NVIDIA NIM (OpenAI-compatible API). To prevent AI hallucinations, RiskTwin enforces a strict separation of concerns: risk scores are computed locally by a deterministic mathematical engine, while the NVIDIA AI model is exclusively tasked with interpreting that structured data to generate executive impact narratives, ISO/NIST compliance mappings, and automated evidence-gap analyses.

AI Layer Detail

The AI is never asked to calculate anything. It receives the scenario engine's structured output — affected assets, before/after risk scores, and relevant ISO/NIST controls — and is instructed to explain it, not invent it.

- **Endpoint:** NVIDIA-hosted OpenAI-compatible chat completions API (integrate.api.nvidia.com/v1/chat/completions).
- **Model:** configurable; currently meta/llama-3.1-8b-instruct, self-hosted on the team's NVIDIA Brev instance.
- **Output contract:** strict JSON with executive_impact, technical_impact, affected_controls, recommended_actions, residual_risk, and priority.
- Same pattern reused for the Evidence screen: the model checks an uploaded document's text against a required-evidence checklist and reports found vs. missing items with a coverage rating.

Sample prompt payload (abridged)

```
Organization: AtlasPay
Scenario: MFA Failure – MFA unavailable for privileged accounts, 24 hours
Affected assets: Active Directory, Payment API, ERP
Affected risks (before -> after): Credential compromise 20 -> 25, Payment API abuse 15 -> 20,
Unauthorized privileged access 15 -> 20
Relevant controls: MFA / Authentication (ISO A.9), Privileged Access Management (ISO A.9.2)
Instruction: analyze using only the data above; do not invent assets or controls.
```

Sample AI response (structure)

```
{
  "executive_impact": "...",
  "technical_impact": "...",
  "affected_controls": "...",
  "recommended_actions": ["Activate emergency authentication controls", "Restrict privileged access", "Restore MFA within 4 hours"],
```

```
"residual_risk": "...",  
"priority": "CRITICAL"  
}
```

9 ISO 27001 / NIST CSF Mapping

A local knowledge base of 15 control topics links each risk to its relevant ISO 27001 clause and NIST CSF function, plus a short list of recommended evidence to collect for an audit. A sample of the mapping used by the Compliance screen:

Control topic	ISO 27001	NIST CSF
MFA / Authentication	A.9 Access Control	PR.AC-1, PR.AC-7
Privileged Access Mgmt	A.9.2, A.9.4	PR.AC-4
Vulnerability Management	A.8.8	ID.RA-1, PR.IP-12
Backup	A.8.13	PR.IP-4, RC.RP-1
Supplier Security	A.5.19-A.5.22	ID.SC-1, ID.SC-4
API Security	A.8.26	PR.DS-2, PR.PT-3

(Full 15-topic mapping in Appendix, Section 15.)

10. Document Intelligence — Evidence Analysis

Users can upload a policy or vendor questionnaire PDF against a chosen control topic. Text is extracted with pdfplumber, then checked by the AI against that topic's required-evidence checklist. The model returns which items were found, which are missing, and an overall coverage rating (None / Partial / Full) — never assuming evidence exists that isn't explicitly present in the document text.

11 Application Screens

Dashboard

Org-level KPIs (assets, open risks, critical assets, control coverage), a color-coded risk distribution chart, and the top risk highlighted.

Risk Register

Full scored risk list with likelihood, impact, score, and level, color-highlighted by severity.

What-If Simulator

Scenario picker, before/after exposure comparison, affected risk table, and on-demand AI-generated executive/technical analysis.

Compliance

Per-risk ISO 27001 and NIST CSF mapping with recommended evidence.

Evidence

PDF upload against a chosen control topic; AI reports which required evidence items were found vs. missing, with a coverage rating.

12 Tech Stack

Layer	Technology
UI	Streamlit
Cloud Hosting & Infrastructure	NVIDIA Brev Workspace
Data processing	Pandas, Altair
Risk/scenario engine	Pure Python (deterministic, no AI)
AI model	NVIDIA NIM (OpenAI-compatible chat completions API)
Document parsing	pdfplumber
Version control	Git / GitHub

13 Project Status

Completed and verified

- Repository structure, data model, and seed data for AtlasPay
- Deterministic Risk Engine (tested against live data)
- What-If Scenario Engine, all 4 scenarios (tested against live data)
- NVIDIA AI integration for scenario analysis (confirmed working)
- ISO 27001 / NIST CSF compliance mapping
- Document Intelligence / Evidence analysis module
- All 5 Streamlit screens, deployed and tested locally
- Pushed to GitHub

Optional / remaining

- One-click Executive Brief PDF export from within the app
- Visual polish (favicon, branding accents)
- Demo rehearsal and timing

14 Demo Script

- 0:00 — Introduce AtlasPay, a fictional Moroccan fintech.
- 0:30 — Show the current risk posture on the Dashboard.
- 1:00 — Ask: "What happens if MFA becomes unavailable for 24 hours?" Run the scenario.
- 1:30 — Show exposure moving from High to Critical with the before/after risk table.
- 2:00 — Walk through the AI-generated impact analysis and recommended actions.
- 3:00 — Upload a policy document on the Evidence screen; show the detected gaps.
- 4:00 — Close on the compliance mapping and, if built, the Executive Brief export.

15 Appendix — Full Data Reference

15.1 — Full Asset Inventory (15 assets)

Asset	Type	Criticality	Internet-exposed
Active Directory	Identity	5	No
Customer Database	Data Store	5	No
Payment API	Application	5	Yes
Web Application	Application	4	Yes
Employee Laptops	Endpoint	3	Yes
Email Server	Communication	3	Yes
Cloud Storage	Data Store	4	Yes
ERP	Application	4	No
HR System	Application	3	No
Backup Server	Infrastructure	5	No
VPN	Network	4	Yes
Firewall	Network	4	Yes
Development Server	Infrastructure	2	No
CI/CD Server	Infrastructure	3	No
Third-Party Payment Provider	Vendor	5	Yes

15.2 — Full Risk Register (13 risks)

Risk	Asset	L	I	Score	Level
Credential compromise	Active Directory	4	5	20	Critical
Ransomware	Backup Server	3	5	15	High
Vendor breach	Third-Party Payment Provider	3	4	12	High
Unpatched critical vulnerability	Web Application	4	4	16	High
Unauthorized privileged access	ERP	3	5	15	High
Payment API abuse	Payment API	3	5	15	High
Phishing-led account takeover	Email Server	4	3	12	High

Risk	Asset	L	I	Score	Level
Endpoint malware infection	Employee Laptops	3	3	9	Medium
Misconfigured cloud storage bucket	Cloud Storage	3	4	12	High
VPN credential brute-forcing	VPN	3	4	12	High
Firewall rule drift	Firewall	2	3	6	Medium
CI/CD pipeline compromise	CI/CD Server	2	4	8	Medium
HR data exposure	HR System	2	3	6	Medium

15.3 — Full ISO 27001 / NIST CSF Control Mapping (15 topics)

Control topic	ISO 27001	NIST CSF
MFA / Authentication	A.9 / A.5.17	PR.AC-1, PR.AC-7
Privileged Access Management	A.9.2, A.9.4	PR.AC-4
Vulnerability Management	A.8.8	ID.RA-1, PR.IP-12
Backup	A.8.13	PR.IP-4, RC.RP-1
Supplier Security	A.5.19-A.5.22	ID.SC-1, ID.SC-4
API Security	A.8.26	PR.DS-2, PR.PT-3
Email Security	A.8.23 / A.5.14	PR.AT-1, DE.CM-4
Endpoint Protection	A.8.7	PR.DS-6, DE.CM-4
Cloud Configuration Management	A.8.9	PR.IP-1, DE.CM-1
Network Security Management	A.8.20 / A.8.21	PR.AC-5, PR.PT-4
DevSecOps / Secure SDLC	A.8.25	PR.IP-2, PR.DS-8
Data Protection	A.5.34 / A.8.11	PR.DS-1, PR.DS-5
Business Continuity	A.5.29-A.5.30	RC.RP-1, RC.IM-1
Incident Response	A.5.24-A.5.28	RS.RP-1, RS.CO-2
Compliance Monitoring	A.5.35-A.5.36	ID.GV-3, DE.DP-1

15.4 — Full Scenario Definitions

Scenario	Target assets	Delta
MFA Failure	Active Directory, Payment API, ERP	Likelihood +1
Unpatched Critical Vulnerability	Web Application, Payment API	Likelihood +1, Impact +1

Scenario	Target assets	Delta
Third-Party Vendor Breach	Third-Party Payment Provider, Payment API, Customer Database	Likelihood +1
Backup System Unavailable	Backup Server	Impact +1

16 Credits

RiskTwin was designed and built by **Chakir Chaimaa** and **Haytham Elgana**.

Chakir Chaimaa — risk model, ISO/NIST mapping, scenario design, AI prompt design, cybersecurity validation.

Haytham Elgana — Streamlit build, dashboard and charts, file upload UX, presentation and demo.

Built as part of a GoMyCode hackathon program, using NVIDIA's AI model hosting for the analysis layer.